

Actividad 1, E Análisis Y Gestión De Riesgos De Una Instalación IT

Miguel De Jesús Chavez Barragán

MODAM Ciberseguridad Web (MEXINGSOF) - Octubre 2025 2Q

Carlos Martin Martínez Farrález

Indices

Introducción a la Metodología De OCTAVE.....	3
Fase 1: Identificación De Activos	3
Fase 2: Identificación De Amenazas Y Vulnerabilidades	4
Fase 3: Selección De Mitigaciones Y Controles	5
Fase 4: Evaluación Del Riesgo Residual Y Plan De Acción	7
.....	8
Conclusiones	8
Referencias.....	9

Introducción a la Metodología De OCTAVE

Este documento narra mi proceso completo de **análisis de riesgos** aplicado a un servicio de tramitación electrónica, utilizando la metodología **OCTAVE** (Operationally Critical Threat, Asset, and Vulnerability Evaluation).

Primero se identificaron los **activos críticos** del sistema (**DEFINIR**) y sus **requisitos de seguridad** (**DEFINIR**), junto con las amenazas y vulnerabilidades asociadas. Cada escenario de riesgo fue evaluado cualitativa y cuantitativamente, asignando probabilidades e impactos, también siguiendo los conceptos vistos en el video (**SeguridadTV, 2020**).

Después se definieron **estrategias de tratamiento** (**DEFINIR**) y **controles** técnicos/organizativos (**DEFINIR**) para mitigar los riesgos más altos.

Fase 1: Identificación De Activos

El primer paso consistió en identificar los **activos esenciales** del sistema de tramitación.

Tomando la definición de activo como concepto clave propuesto por (SeguridadTV, 2020) que lo describe como cualquier cosa que tenga valor para la organización, ya sea tangible o intangible, podemos asumir que los componentes tecnológicos críticos para este proceso son:

- El servidor principal de tramitación.
- Los PCs de oficina.
- La base de datos de expedientes.
- La aplicación de gestión.
- El sistema de correo electrónico.
- La infraestructura de red.
- La sala de equipos.

Estos activos fueron evaluados según los términos de **Confidencialidad, Integridad y Disponibilidad** (C/I/A), así como su impacto potencial ante una falla. A continuación, se

muestra la tabla de activos clave elaborada (cada activo fue catalogado por tipo, propietario, ubicación y valorizado en C/I/A y nivel de impacto):

ID Activo	Nombre del Activo	Tipo de Activo	Propietario	Ubicación	Confidencialidad	Integridad	Disponibilidad	Impacto	Notas
1	10 Unidades PCs de Oficina	Hardware	Tramitacion	Oficinas (LAN)	Medio	Medio	Medio	Medio	Sin discos extraíbles; reinstalación periódica.
2	Servidor General	Hardware	Sistemas	Sala de Equipos	Alto	Alto	Alto	Alto	Almacena app, BD y correo; no hay redundancia local.
3	SW Gestion de Expedientes	Software	Tramitacion	Servidor local	Alto	Alto	Alto	Alto	Sistema propio de tramitación; soporte interno limitado.
4	Base de datos de expedientes	Base de datos	Tramitacion	Servidor local	Alto	Alto	Alto	Alto	Contiene datos personales; se envía backup al archivo central.
5	Sistema de correo electronico	Software	Tramitacion	Servidor local	Medio	Medio	Medio	Medio	Mensajería interna; no hay filtros antispam robustos.
6	Conexion de internet	Servicio Externo	Tramitacion	Externa (ISP)	Bajo	Bajo	Alto	Alto	Soporta web/VPN; backup RDSI activado ante caídas.
7	Cortafuegos	Hardware	Sistemas	Sala de Equipos	Medio	Alto	Alto	Alto	Controla acceso Internet; único dispositivo de seguridad de red.
8	Sala de Equipos	Infraestructura	Sistemas	Edificio	Medio	Medio	Alto	Alto	Cerrada con llave, detector de incendios; lejos de tubería.

Cada activo fue calificado según lo que implicaría su nivel de seguridad. Por ejemplo, el **Servidor** y la **Base de Datos** obtuvieron valoraciones **altas** en C/I/A, dado que contienen **datos sensibles** y soportan el **funcionamiento operativo** esencial de la unidad.

En contraste, los **PCs de oficina** se valoraron como **medios** en C/I/A, puesto que solo almacenan expedientes de forma temporal y existe un procedimiento sencillo y periódico para reinstalar el sistema íntegro.

Esta valoración aporta los cimientos de las siguientes fases del análisis de riesgos, ya que define claramente **los recursos a proteger** e identifica cuáles son más críticos en términos de **Confidencialidad, Integridad y Disponibilidad**.

Fase 2: Identificación De Amenazas Y Vulnerabilidades

Siguiendo la definición de activos que identificamos, generamos escenarios de amenazas para cada activo, una amenaza concreta y una vulnerabilidad. Ente los escenarios considerados lo que desacataron mayormente fueron:

- **Ataques de ransomware:** cifrado malicioso de expedientes o sistemas críticos.
- **Acceso no autorizado a expedientes:** intrusiones internas o externas a la base de datos.
- **Interrupción del servicio:** fallos de conexión a Internet o problemas en la red local.

- **Pérdida o fuga de información vía APIs externas:** por ejemplo, exposición de datos durante interacciones con el archivo central.
- **Manipulación o alteración de datos de tramitaciones:** cambios maliciosos en expedientes abiertos o cerrados.
- **Errores de configuración en servidores o bases de datos:** desbordamientos, parches faltantes o servicios inseguros.
- **Saturación por picos de carga o ataques DDoS:** sobrecarga del enlace ADSL o del servidor web.

En cada escenario se evalúa la **probabilidad** en una escala del 1 al 5 y el **impacto** percibido en el negocio. Esto permite calcular el **puntaje de riesgo** (Probabilidad × Impacto) y asignarle una calificación cualitativa.

ID Escenario	Activo Relacionado	Amenaza	Vulnerabilidad	Probabilidad	Impacto	Riesgo (Score)	Riesgo (Cualitativo)	Controles Existentes	Controles Recomendados
1	10 Unidades PCs de Oficina	Infeccion de malware	No hay antivirus corporativo ni politicas claras.	3	2	6	Medio	Cortafuegos perimetral y sin antivirus en PCs.	Instalar antivirus endpoint; bloqueo USB/email.
2	Servidor General	Fallo de disco duro	Servidor único sin respaldo local ni redundancia.	3	5	15	Alto	Se envían expedientes cerrados al archivo.	Implementar backups regulares locales;
3	Conrtafuegos	Configuracion incorrecta o Ataque externo	Firewall único sin IDS/IPS ni monitoreo activo.	1	5	5	Medio	Reglas básicas de tráfico (web y correo).	Auditorías de configuración periódicas; añadir IDS/IPS.
4	SW de gestions	Vulnerabilidad de software	App heredada sin parches ni pruebas de seguridad.	3	5	15	Alto	Acceso autenticado actual del software.	Análisis y parcheo continuo; pruebas de seguridad.
5	Base de datos	Acceso no autorizado o Fuga de datos	Contraseñas débiles; privilegios demasiado amplios.	3	5	15	Alto	Autenticación tradicional por contraseña.	Cifrado de datos; reforzar controles de acceso; MFA.
6	Sistema de Correos	Phishing o Suplantacion	No hay filtro antispam; usuarios sin capacitación.	4	3	12	Alto	Servidor y cliente de correo actualizados.	Implementar filtro antispam; formación en seguridad.
7	Sala de Equipos	Incendio o desastre fisico	Detector de humo sin extinción automática ni gas.	1	5	5	Medio	Detector de incendios activo sala con llave.	Instalar extintores automáticos;

Por ejemplo, en el Escenario 1 "Infección por malware" en los PCs, una probabilidad media de 3 e impacto de negocio siendo 2 resultan en un riesgo de 6 con el cualitativo siendo Medio. Además, se documentan los **controles existentes** y se proponen **controles recomendados** para mitigar cada vulnerabilidad.

Fase 3: Selección De Mitigaciones Y Controles

Al revisar los riesgos identificados de cada activo podemos definir estrategias de tratamiento según el riesgo aceptable y costos asociados. Siguiendo las definiciones de conceptos estrategias de riesgos mitigados como indica la página (DataGuard, 2023) tenemos 4 tipos de Estrategias:

- **Evitar:** eliminar la causa del riesgo (por ejemplo, desactivar una funcionalidad no esencial vulnerable).

- **Reducir:** implementar controles para disminuir probabilidad o impacto (p.ej. reforzar autenticación, cifrado, copias de seguridad).
- **Transferir:** asignar el riesgo a terceros (por ejemplo, contratar seguro o delegar servicio a un proveedor con garantía de servicio).
- **Aceptar:** asumir el riesgo cuando sea leve o el costo de mitigarlo desproporcionado.

Estas opciones se anotaron en la matriz como “Estrategia de Mitigación” para cada escenario. Por ejemplo, ante riesgos altos se priorizó reducir (mejorar controles) o evitar (modificar procesos), mientras que riesgos menores se podrían aceptar o monitorizar pasivamente.

	A	B	C	D	E	F	G
	ID Escenario	Nivel de Riesgo Inicial	Estrategia de Mitigación	Controles Aplicados	Nivel de Riesgo Residual	Responsable	Fecha de Revisión
	1	Medio	Evitar	Antivirus instalado, políticas de bloqueo de USB/email.			
	2	Alto	Reducir	Copias de seguridad periódicas y duplicación de datos.			
	3	Medio	Reducir	Implementación de IDS, revisiones de configuración.			
	4	Alto	Reducir	Parches regulares, auditoría de seguridad del software.			
	5	Alto	Reducir	Cifrado en base de datos, MFA para acceso.			
	6	Alto	Evitar	Filtro antispam avanzado, capacitación a usuarios.			
	7	Medio	Reducir	Extintores automáticos, simulacros de emergencia.			

Con las estrategias definidas, se enlistaron los **controles a aplicar** necesarios. Entre los controles recomendados destacan:

- **Autenticación multifactor (MFA):** fortalece el acceso a sistemas críticos.
- **Mejoramiento de servidores:** deshabilitar servicios innecesarios, aplicar parches y configuraciones seguras con duplicación de datos.

- **Implementación sistema de monitoreo centralizado:** para detectar incidentes en tiempo real.
- **Cifrado de datos en tránsito y reposo:** proteger información confidencial en la base de datos y comunicaciones.
- **Backups periódicos probados:** realizar copias de seguridad locales y en ubicaciones remotas y verificar su restauración.
- **Validación y sanitización de datos en APIs:** proteger integraciones con el archivo central.
Algunos controles ya existían (por ejemplo, firewall perimetral, autenticación básica), otros se propusieron. Estos controles se registraron en la matriz como “Controles Aplicados” y también se marcó su estado riesgos residual en la etapa final.

Fase 4: Evaluación Del Riesgo Residual Y Plan De Acción

Tras planificar la aplicación de los controles recomendados, se estimó el **nivel de riesgo residual** para cada escenario, recalculando la probabilidad e impacto asumibles con las salvaguardas propuestas. Se llenó la columna “Nivel de Riesgo Residual” en la matriz final.

En la mayoría de los casos, los riesgos inicialmente altos o medios pasaron a niveles medios o bajos. Por ejemplo, instalando antivirus y políticas USB adecuadas, el riesgo de malware en PCs (Escenario 1) baja a “Bajo”. Este proceso de revisión confirma que los controles mitigatorios son efectivos en teoría, aunque debe validarse en la práctica.

Para asegurar el seguimiento, a cada control o grupo de medidas se asignó un **responsable encargado** (por ejemplo, administrador de sistemas, jefe de TI, equipo de desarrollo, seguridad física) y se fijó una **fecha de revisión** objetivo. Esto genera un cronograma de implementación y seguimiento continuo. En la Matriz final (Matriz de Estrategias de Mitigación y Riesgo Residual) se documentaron las columnas de “responsable” y “Fecha de Revisión” junto a cada medida. De esta manera, el ciclo de OCTAVE-S concluye garantizando que los resultados sean accionables y auditables.

A	B	C	D	E	F	G
ID Escenario	Nivel de Riesgo Inicial	Estrategia de Mitigación	Controles Aplicados	Nivel de Riesgo Residual	Responsable	Fecha de Revisión
1	Medio	Evitar	Antivirus instalado, políticas de bloqueo de USB/email.	Bajo	Admin. de Sistemas	31/12/2025
2	Alto	Reducir	Copias de seguridad periódicas y duplicación de datos.	Medio	Admin. de Sistemas	31/12/2025
3	Medio	Reducir	Implementación de IDS, revisiones de configuración.	Bajo	Admin. de Sistemas	31/12/2025
4	Alto	Reducir	Parches regulares, auditoría de seguridad del software.	Medio	Equipo de Desarrollo	31/02/2026
5	Alto	Reducir	Cifrado en base de datos, MFA para acceso.	Medio	Admin. BD	31/02/2026
6	Alto	Evitar	Filtro antispam avanzado, capacitación a usuarios.	Bajo	Jefe de IT	30/11/2025
7	Medio	Reducir	Extintores automáticos, simulacros de emergencia.	Bajo	Seguridad Física	30/11/2025

Conclusiones

La aplicación de la metodología OCTAVE proporciona un **análisis de riesgos completo y alineado con buenas prácticas** en el contexto de la tramitación electrónica municipal. En particular, permitió:

- **Identificar con claridad los activos críticos** (datos, sistemas e infraestructura esenciales para la continuidad del servicio).
- **Evaluar amenazas y vulnerabilidades operacionales relevantes** de manera estructurada, vinculando cada amenaza a activos específicos.
- **Determinar objetivamente niveles de riesgo iniciales** mediante matrices de probabilidad e impacto, priorizando los riesgos más significativos.
- **Proponer controles enfocados en riesgos altos** o críticos (autenticación multifactor, copias de seguridad, auditorías, cifrado, etc.), siguiendo marcos de referencia estándares.
- **Definir responsables y cronogramas** que aseguran la implementación práctica de las salvaguardas.

En resumen, el resultado final es un informe de riesgos **tangible y trazable**, listo para servir de base en planes de seguridad, auditorías internas o procesos de cumplimiento normativo.

Referencias

Caralli, Richard A., Stevens, James F., Young, L. R., & Wilson, W. R. (2007). *Introducing OCTAVE Allegro: Improving the Information Security Risk Assessment Process* (No. CMU/SEI-2007-TR-012). Software Engineering Institute, Carnegie Mellon University. https://www.sei.cmu.edu/documents/786/2007_005_001_14885.pdf

Emrick Etheridge. (2023, mayo 11). ISO 27001 risk management: Strategies for success [Blog]. *DataGuard*. <https://www.dataguard.com/blog/iso-27001-risk-management-strategies>

SeguridadTV (Director). (2020, mayo 10). *Metodología de análisis de riesgos con Octave Allegro (Parte I)* [Video]. SeguridadTV. <http://www.youtube.com/watch?v=U8zQS8Q9nKw>